

DRAFT REQUEST FOR INFORMATION UNDER REGULATION EU 2024 1689

Regulatory Response to Publicly Reported Unsanctioned Agent Behaviour During Cyber Testing and the July 2026 Hugging Face Incident

Sarah Jones | Sunil Franklin | Akash Awan

With Apart Research

Abstract

This report presents a draft Request for Information (RFI) prepared under Article 91(1) of Regulation (EU) 2024/1689, the AI Act. The RFI concerns publicly reported unsanctioned agent behaviour during cyber testing and the July 2026 Hugging Face incident. Its purpose is not to determine liability. Rather, it provides a proportionate mechanism for the European AI Office to obtain the documentation needed to assess whether the relevant provider and model fall within the AI Act, whether a general-purpose AI model may present systemic risk, and whether the provider has met the documentation, evaluation, incident-reporting, and cybersecurity obligations that apply. The report translates the draft RFI into a structured research submission. It sets out the legal basis, public-information context, safeguards for confidential and cybersecurity-sensitive material, and the 19 categories of information sought in Annex I. It also explains why the request is organised around verifiable records: the incident timeline, model and configuration status, evaluation conditions, evidence integrity, containment, and mitigation. The result is a regulator-facing instrument designed to support fact-finding without presuming that the public account is complete or that an infringement has occurred.

1. Introduction

Advanced AI systems are increasingly evaluated in environments that combine tool use, network access, external services, agentic orchestration, and multi-agent interaction. Where publicly reported behaviour indicates that an agent may have acted outside the intended evaluation design, regulators need a way to distinguish established facts from incomplete reporting and to assess the provider's legal obligations without overreaching into sensitive technical material. This project addresses that procedural problem.

The draft RFI is directed to the provider of the relevant general-purpose AI model, or its authorised representative where applicable. Under Article 91(1) AI Act, the Commission may request the documentation prepared under Articles 53 and 55 and any additional information necessary to assess compliance. The request therefore asks for records rather than admissions: identity and scope information, technical documentation, systemic-risk assessments, evaluation and incident records, and evidence of corrective action. It does not constitute a finding of infringement.

Contributions

Structured regulatory instrument. A draft Article 91(1) RFI that turns the incident into 19 defined information requests, grouped by legal function and evidentiary need.

Traceable legal framework. A framework linking scope, documentation, systemic-risk, monitoring, evaluation, enforcement, confidentiality, and procedural provisions of the AI Act to the evidence requested.

Secure evidence model. An Annex II production protocol that protects confidential business information, personal data, and dual-use-sensitive cybersecurity material while preserving the Office's ability to evaluate compliance.

2. Related Work and Public Information

The RFI is informed by publicly available reporting rather than by a settled factual record. The cited material includes the METR and Redwood Research investigation, Brief independent investigation of agents' behavior, reasoning and collaboration in the OpenAI / Hugging Face hacking incident (26 August 2026); Hugging Face's Security incident disclosure - July 2026; the AI Safety Institute's Incident Report: Unsanctioned Agent Behaviour During Cyber Testing; and OpenAI's Hugging Face Incident Technical Report. Public incident entries, including those maintained through collusion.wiki, provide additional context.

This public material is a trigger for regulatory inquiry, not a substitute for provider-held evidence. The draft expressly allows the provider to present a different account where supported by records. If a provider considers that a model, model version, configuration, system, environment, activity, or output is outside the AI Act's scope, it must explain the legal and factual basis and provide supporting records. This preserves both the integrity of the inquiry and the distinction between allegation, evidence, and regulatory finding.

3. Methods and Legal Design

3.1 Legal basis, supervision, and enforcement

Article 91(1) is the immediate legal basis for the request. The broader design also reflects the Commission's exclusive power to supervise and enforce Chapter V in respect of providers of general-purpose AI models under Article 88, its monitoring role under Article 89, its power to conduct model evaluations under Article 92 where Article 91 information is insufficient, and its power to request measures under Article 93 where the relevant legal conditions are met.

The enforcement context is stated carefully. For providers of general-purpose AI models, the Commission may impose fines not exceeding 3% of annual total worldwide turnover in the preceding financial year or EUR 15,000,000, whichever is higher, for intentional or negligent infringement, failure to comply with an Article 91 request, provision of incorrect, incomplete, or misleading information, failure to comply with an Article 93 measure, or failure to make a model available for an Article 92 evaluation. Where the conduct is assessed in the provider's capacity as an operator of an AI system, Article 99 may separately apply: Article 99(3) provides for fines of up to EUR 35,000,000 or 7% of total worldwide annual turnover for non-compliance with a prohibited AI practice under Article 5; Article 99(4) provides for fines of up to EUR 15,000,000 or 3% of turnover for relevant operator infringements, including the applicable AI Office provisions as amended by Regulation (EU) 2026/1744; and Article 99(5) provides for fines of up to EUR 7,500,000 or 1% of turnover for incorrect, incomplete, or misleading information in response to a request.

The report also recognises that providers may rely on codes of practice under Articles 53(4), 55(2), and 56 until harmonised standards are published. The RFI therefore asks a provider relying on an approved Code of Practice to identify the commitments, measures, documentation, model reports, incident reports, or alternative means of compliance on which it relies.

3.2 Scope, safeguards, and response protocol

The scope analysis is grounded in Article 2 and Article 3(63). It asks whether relevant systems or general-purpose AI models were placed on the Union market or put into service, whether outputs were used in the Union, and what market-placement, first-use, and access dates apply. It also asks the provider to substantiate any position that activity was exclusively scientific research and development or occurred before market placement or putting into service. For each in-scope model, the provider must address Article 52 notification, systemic-risk designation, and the Article 51(1) conditions, including the Article 51(2) presumption where relevant.

The production protocol is deliberately protective. Information obtained in connection with Articles 53 and 55 is subject to the confidentiality obligations in Articles 53(7), 55(3), and 78. Article 2(7) applies Union law on personal-data protection, privacy, and confidentiality of communications. Providers should avoid producing personal data unless strictly necessary; if they do, they should identify the category, necessity, minimisation or pseudonymisation steps, and proposed secure handling. Where material is privileged, a trade secret, confidential business information, personal data, or cybersecurity-sensitive, the provider must identify the items and legal basis for restriction and, where appropriate, offer a non-confidential summary, redaction, alternative evidence, metadata, or secure inspection under Articles 78 and 75d(2).

Live credentials, secret values, unrestricted model weights, operational exploit instructions, and other material that would materially increase cybersecurity risk should not be sent through ordinary channels. The appropriate alternatives are restricted-access review, escrow, in-person inspection, secure data-room access, redacted production, or another proportionate arrangement. Where operator proceedings fall within Article 75(1), information collected under Article 75a is used only for AI Act purposes under Article 75a(8), with the procedural safeguards in Article 75d and the economic-operator protections in Article 94.

3.3 Drafting approach and terminology

Wherever possible, the RFI reproduces the exact wording of the AI Act and the General-Purpose AI Code of Practice rather than paraphrasing it. Defined terms, article references, and obligations are stated as they appear in those texts. This keeps technical jargon that does not appear in the AI Act or the Code of Practice limited in the request, so that the provider, the AI Office, and any reviewer can trace each question directly to its legal source.

4. Results: The Draft Request for Information

The main result is a complete, evidence-oriented RFI. It requires a response to every Annex I item, correct, complete, and not misleading, under Article 91(1) or Article 75a(3). Previously submitted documents may be cross-referenced by submission date, Commission reference number, title, and relevant section, provided that all incident-specific updates, corrections, deviations, and gaps are supplied. If information is unavailable, unretained, held by a third-party value-chain actor, or otherwise inaccessible, the provider must explain why, identify the holder where known, and describe reasonable efforts to obtain, preserve, or seek access under Article 75(3).

Documents should be supplied in their original electronic format, with an index and metadata establishing source, date, custodian, and integrity. The response must identify assumptions, approximations, and uncertainties; cover the full incident-relevant period, including precursor events, near-misses identified through post-market monitoring, and follow-on incidents; specify exact model identifiers and versions with complete logs; and define system boundaries, including software integration, tool use, and relevant third-party or value-chain actors under Article 25.

Group Questions and required information

Group	Questions and required information
A. Scope and AI Act status	Q1. Identify the provider, responsible entities for development, evaluation, operation, and security, and any Union authorised representative. Q2. Identify each involved or potentially involved model, version, configuration, access status, system context, safeguards, and factual role. Q3. Provide a specific Article 2 analysis of Union connection, research-exemption claims, internet access, third-party production-system interaction, and effects on Union infrastructure. Q4.

Group	Questions and required information
	Address Article 3(63), Article 52, Article 51(1), Article 51(2), and supporting evidence.
B. Article 53 documentation	Q5. Produce incident-relevant Article 53(1)(a) technical documentation and identify each document's relationship to the incident and whether it was created or amended after the incident period. Q6. Produce Article 53(1)(b) information supplied to downstream providers whose instances were involved. Q7. Describe architecture, integration, security boundaries, trust relationships, permissions, interfaces, and tool or network access paths.
C. Systemic risk and safeguards	Q8. Produce Article 55(1)(b) documentation on the detection, assessment, and mitigation of incident-evidenced high-impact capabilities and systemic risks. Q9. Provide the Article 3(49) serious-incident assessment and Article 55(1)(c) reporting records, or records supporting a decision not to report. Q10. Provide Article 55 evaluation and adversarial-testing records, evaluation conditions, cybersecurity controls, monitoring records, human approval controls, and any relevant gaps, bypasses, or failures.
D. Chronology, precursors, and affected systems	Q11. Provide precursor records, incident chronology, non-user-visible instructions and meta-prompts, command-execution controls, event-specific timestamps, and root-cause analysis. Q12. Provide records of precursor incidents, decisions to continue testing or modify safeguards, and every unauthorised external-system interaction, including affected data categories and containment actions. Q13. Provide prior-knowledge, foreseeability, incentive, scoring, benchmark, persistence, and multi-agent evaluation-design analyses. Q14. Provide records of intended multi-agent capability, observed collaboration, communication mechanisms, contributing factors, evidence, limitations, and mitigation.
E. Evidence integrity and containment	Q15. Provide a complete or partial inventory of incident records, account for missing or lost material, and describe reconstruction steps. Q16. Describe integrity and authenticity controls, control operation, manipulation attempts, and independent corroborating evidence. Q17. Describe evidence-preservation and containment actions, including evaluation shutdown, isolation, snapshots, log preservation, credential containment, and third-party measures.
F. Corrective and preventive measures	Q18. Describe completed, ongoing, and planned corrective and preventive measures across models, configurations, evaluation environments, and infrastructure. Q19. Provide validation, security review, red-team, monitoring, recurrence-testing, systemic-risk, model-report, and residual-risk evidence demonstrating the effectiveness and limits of mitigation.

5. Discussion and Limitations

Discussion

The RFI is designed to make the evidentiary chain visible. A regulator cannot assess an incident only by looking at the final event. The request therefore connects model identity and configuration to the evaluation environment, safeguards, precursor events, monitoring signals, preservation decisions, and subsequent mitigation. This structure matters because a provider's legal position on scope or systemic risk may depend

on facts distributed across technical documentation, system logs, security controls, and decisions made during the incident-relevant period.

The design also balances accountability with operational safety. It asks for the records needed to assess compliance but does not require a provider to transmit secret values, live credentials, unrestricted weights, or exploit instructions through ordinary channels. That balance is central to the RFI's proportionality: the Office can examine whether safeguards, documentation, reporting, and mitigation were adequate while reducing avoidable cybersecurity and confidentiality risks.

Limitations

First, the report is based on a draft RFI and publicly reported incident information. Public accounts may be incomplete, disputed, or later revised. The report therefore does not treat those accounts as conclusive and does not assert that an infringement occurred. Provider-held records may clarify, qualify, or contradict aspects of the public narrative.

Second, the application of Articles 2, 51, 52, 53, 55, 75, 75a, 75d, 78, 88, 89, 91, 92, 93, 94, and 99 will depend on facts that are not established in the public record, including the provider's role, model status, Union connection, evaluation conditions, and the legal characterisation of the conduct. This document is a research and regulatory-drafting exercise, not an adjudication or a finding of liability.

Third, the most probative technical material may also be the most sensitive. Trade secrecy, legal privilege, personal data, classified or restricted information, and cybersecurity concerns can constrain what is produced in ordinary form. Annex II addresses this with alternatives, but secure review arrangements can still affect the pace, completeness, and ease of external verification.

Finally, the draft leaves operational details for completion, including the date, response deadline, submission channel, recipient entity, and the final legal and editorial review of individual formulations. Those details should be settled before any formal regulatory use.

Future Work

The immediate next step is legal and editorial validation of the draft against the final applicable text of the AI Act and the procedural posture in which it would be used. The team should finalise the addressee, response deadline, and secure submission channel; confirm the final scope and terminology of all 19 questions; and prepare a response index and secure-data-room protocol that can be used in practice.

Further work should also develop a reusable incident-response RFI playbook. This could include a standard evidence-preservation notice, a risk-based decision rule for requests involving sensitive technical material, a model-configuration inventory, and a structured method for comparing provider records with independent reporting. Such work would make future inquiries faster and more consistent without weakening the case-specific analysis required by the AI Act.

6. Conclusion

This project delivers a draft Article 91(1) Request for Information for a publicly reported AI incident involving unsanctioned agent behaviour during cyber testing and the July 2026 Hugging Face incident. The report converts the RFI into a clear submission-ready account of its legal basis, evidence model, safeguards, and intended regulatory use.

Its principal contribution is a complete, proportionate framework for obtaining and evaluating the records needed to assess AI Act compliance. The request is deliberately rigorous about documentation, model

evaluation, systemic-risk assessment, incident reporting, cybersecurity, evidence integrity, and corrective action, while remaining explicit that fact-finding is not a finding of infringement and that sensitive material requires secure handling.

Code and Data

Code repository: Not applicable. This project is a policy and regulatory-drafting exercise and does not involve code.

Data and datasets: No dataset was created. The work relies on publicly available incident reporting and provider-held documentation that would be requested through the RFI.

Other artefact: Draft Request for Information under Regulation (EU) 2024/1689, including Annex I and Annex II Available on: [Google Drive](#)

Author Contributions

Sarah Jones drafted the Request for Information, including the legal basis, scope and definitions, safeguards, response instructions, and Annexes. Akash Awan and Sunil Franklin reviewed the draft and contributed to its regulatory framing and refinements. All authors reviewed the final submission report.

References

1. Regulation (EU) 2024/1689 of the European Parliament and of the Council laying down harmonised rules on artificial intelligence (AI Act).
2. METR and Redwood Research (2026). Brief independent investigation of agents' behavior, reasoning and collaboration in the OpenAI / Hugging Face hacking incident. Published 26 August 2026.
3. Hugging Face (2026). Security incident disclosure - July 2026.
4. AI Safety Institute (AISi) (2026). Incident Report: Unsanctioned Agent Behaviour During Cyber Testing.
5. OpenAI (2026). Hugging Face Incident Technical Report.
6. collusion.wiki. Public incident entries and supporting documentation. <https://collusion.wiki/>

Appendix A: Annex II Production Format and Secure Handling

Response index. Map each Annex I question to the documents or records produced.

Withheld or alternative production. Identify each document withheld, redacted, or produced through an alternative secure mechanism, and state the basis for that treatment.

Ordinary-channel exclusions. Do not send live credentials, secret values, unrestricted model weights, or operational exploit instructions through ordinary channels.

Secure handling. Propose proportionate arrangements for highly sensitive cybersecurity material, unrestricted model-access material, source code, confidential model-weight information, or personal data where production is necessary.

Continuing investigation. Identify each response that is provisional, incomplete, or subject to continuing investigation, and provide the expected supplementation date.

LLM Usage Statement

We used three AI assistants while drafting the RFI. Solaria was used only for the initial analysis of the AI Act and the General-Purpose AI Code of Practice, producing a first version that correlated the relevant provisions with the reported incident. Claude (Anthropic) was used to validate that the terminology in the RFI matches the AI Act and the Code of Practice. Microsoft Copilot was used to check for duplication.